🌐 Module 05: Web Application Penetration Testing

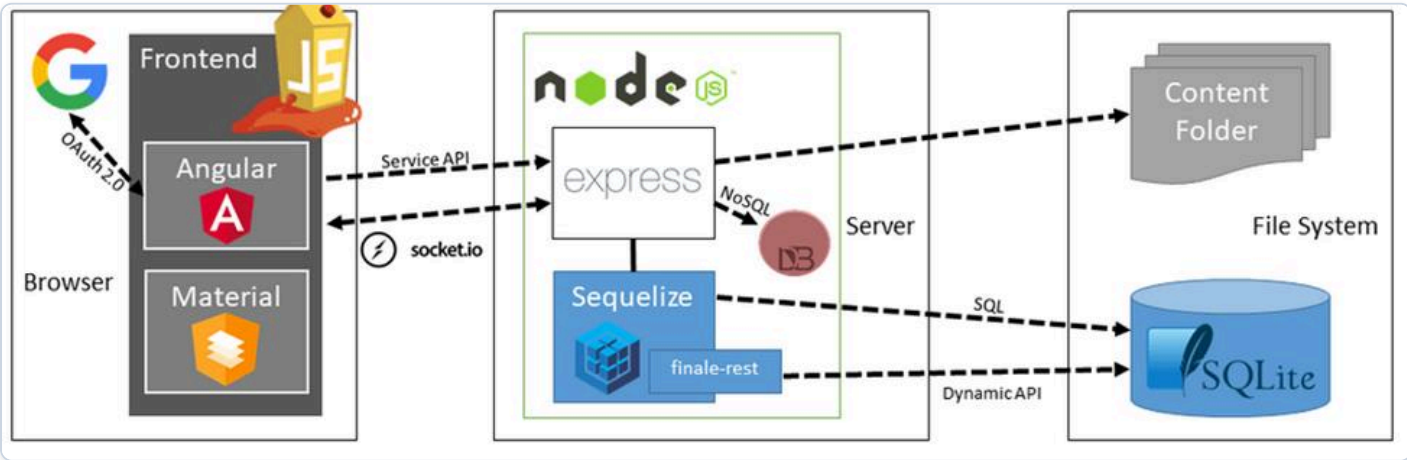
```
# Exercise 5: Exploiting Broken Object-level Authorization in Web Application
```

Scenario

For this lab, we are going to use the OWASP Juice Shop to test web application security testing skills. The OWASP Juice Shop is a pure web application implemented in JavaScript and TypeScript (which is compiled into regular JavaScript). In the front end, the popular Angular framework is used to create a single-page application. The user interface layout implements Google's Material Design using Angular Material components and Angular Flex-Layout to achieve responsiveness. All icons found in the UI originate from the Font Awesome library.

JavaScript is also used in the backend as the exclusive programming language: An Express application hosted in a Node.js server delivers the client-side code to the browser. It also provides backend functionality to the client via a RESTful API. As an underlying database, lightweight SQLite was chosen because of its file-based nature, making it easy to create programmatically without needing a dedicated server. Sequelize and `finale-rest` are used as an abstraction layer from the database.

As an additional data store, MarsDB is part of OWASP Juice Shop. It is a JavaScript derivative of the MongoDB NoSQL database and is compatible with most of its query/modify operations. An example of the architecture is shown below:



Objective

The objective of this lab is to demonstrate how to identify and exploit Broken Object-Level Authorization (BOLA) / Insecure Direct Object References (IDOR) vulnerabilities in web application REST APIs using Burp Suite.

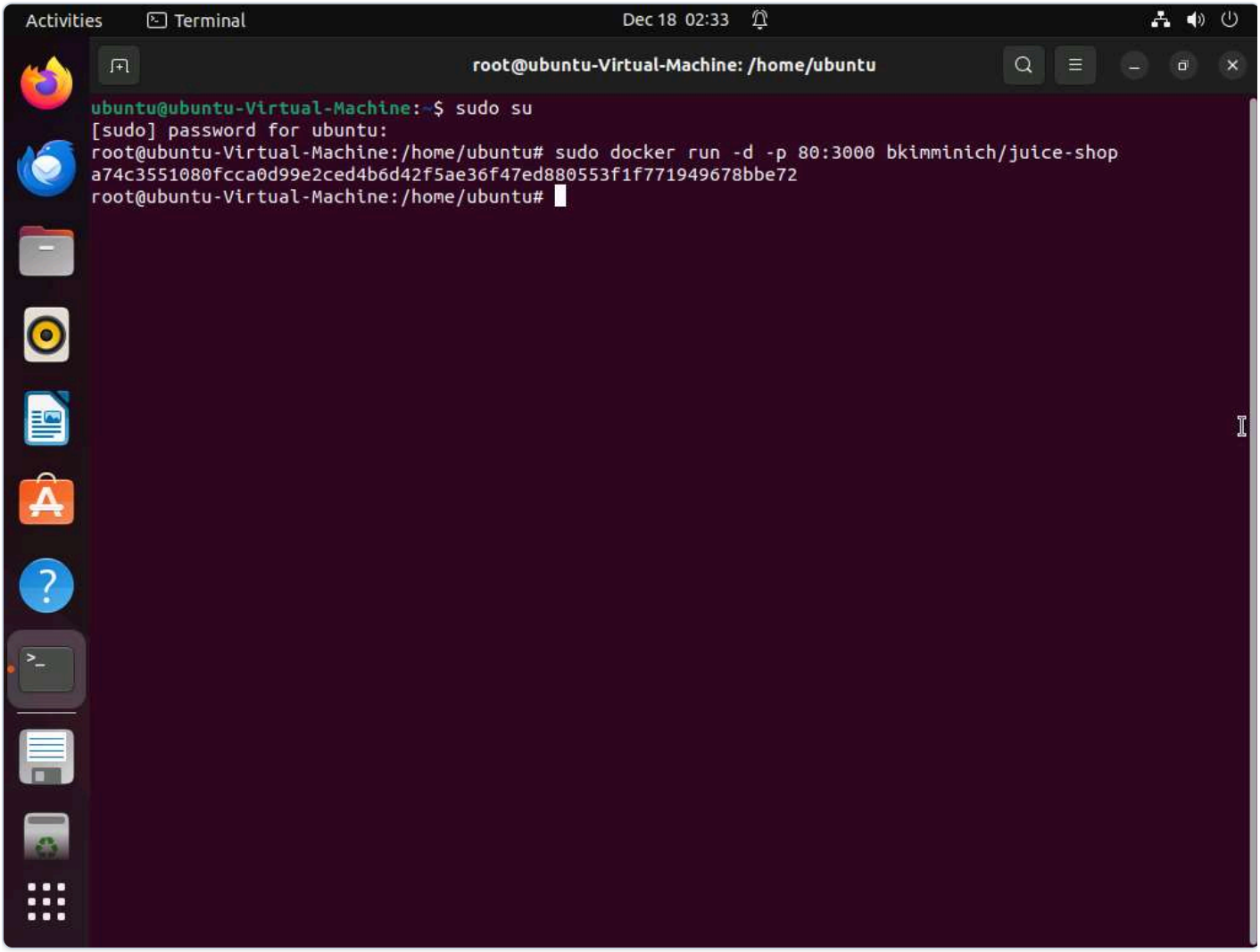
Task 1: Exploiting Broken Object-level Authorization in Web Application

In this task, we initialize the OWASP Juice Shop application on the target server, register a new account, capture API requests using Burp Suite Proxy, and manipulate basket resource IDs in Burp Repeater to access other users' shopping carts.

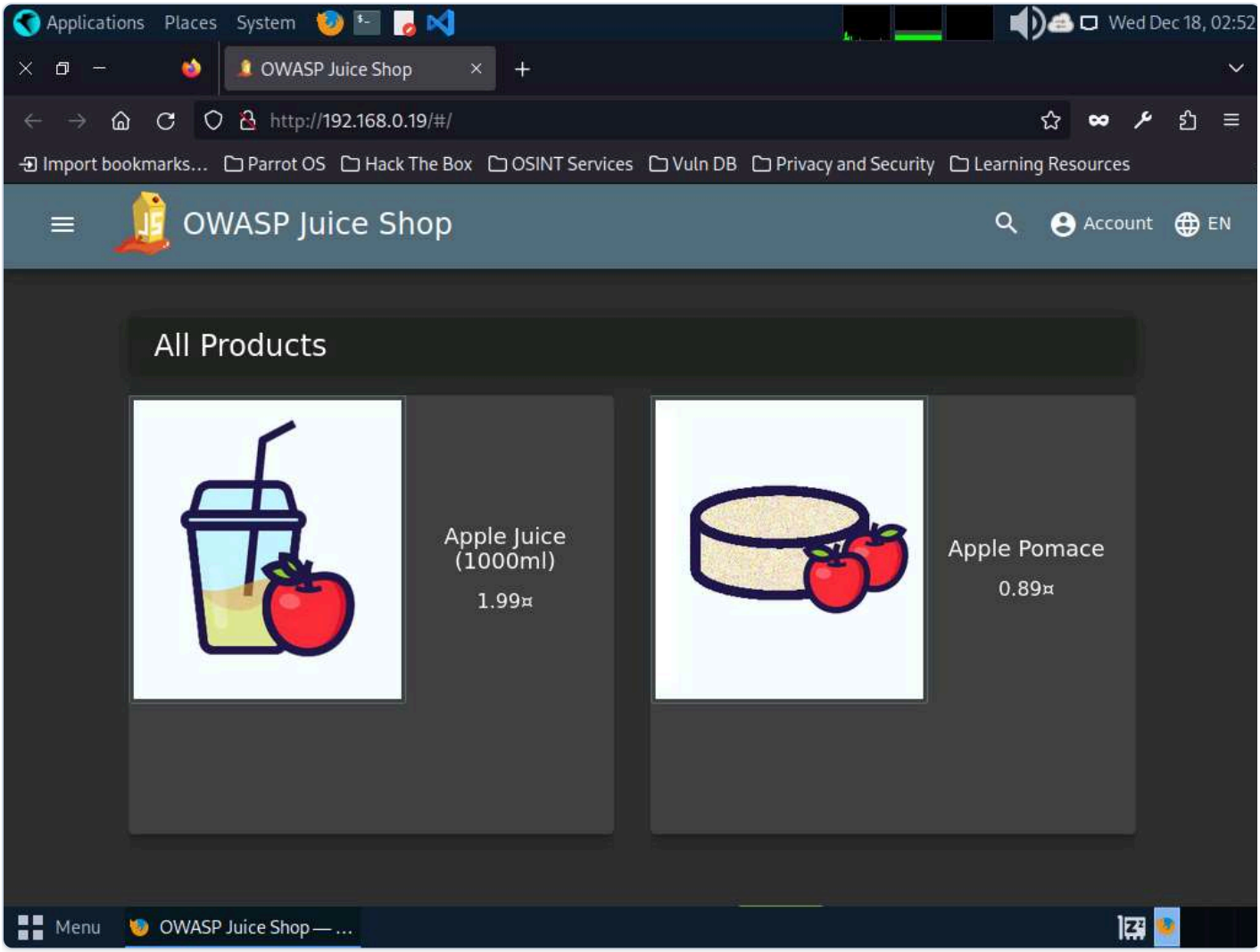
Lab Tasks

1. Click on **Ubuntu** to switch to the Ubuntu machine, type **toor** in the Password field, and press Enter.

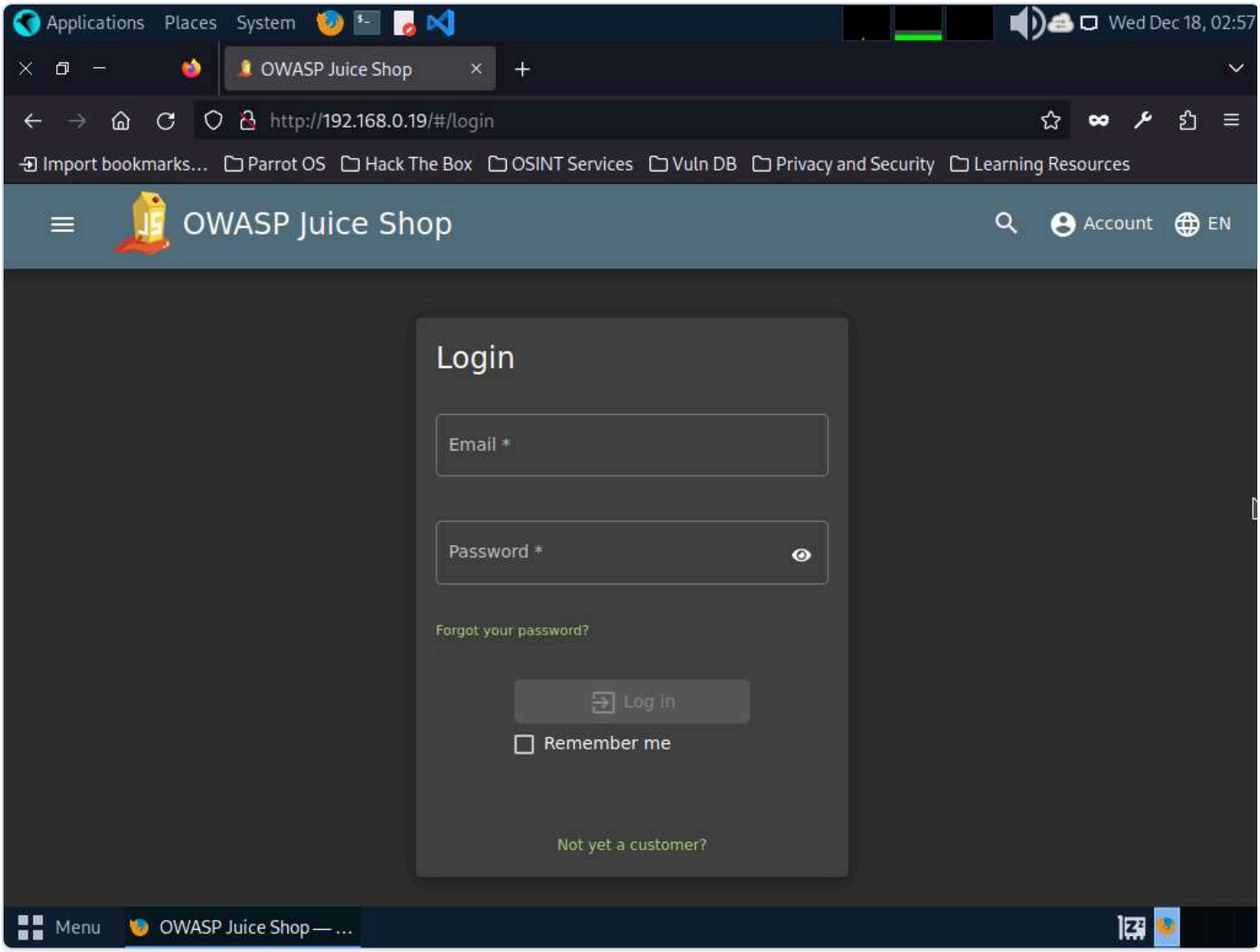
2. Open a terminal with root privileges and run **sudo docker run -d -p 80:3000 bkimminich/juice-shop** to start the Juice Shop container.
3. *(If you receive any error message, run **service apache2 stop** first.)*



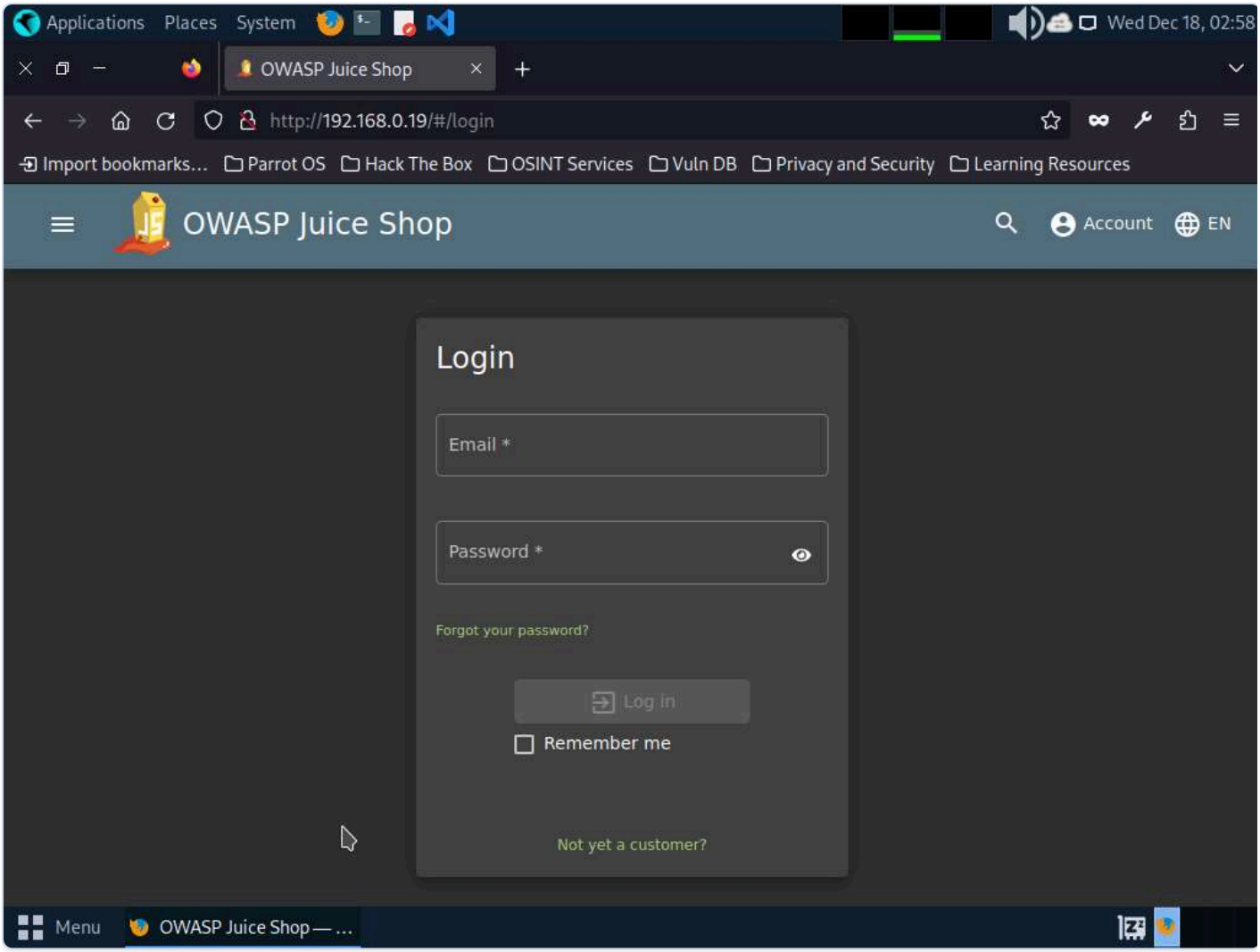
1. Switch to the **Parrot Security** machine and log in with **pentester** / **toor**.
2. Open a web browser and type **http://192.168.0.19** in the address bar and press Enter.
3. *(If prompted with a notification about the vulnerable server, click Dismiss.)*



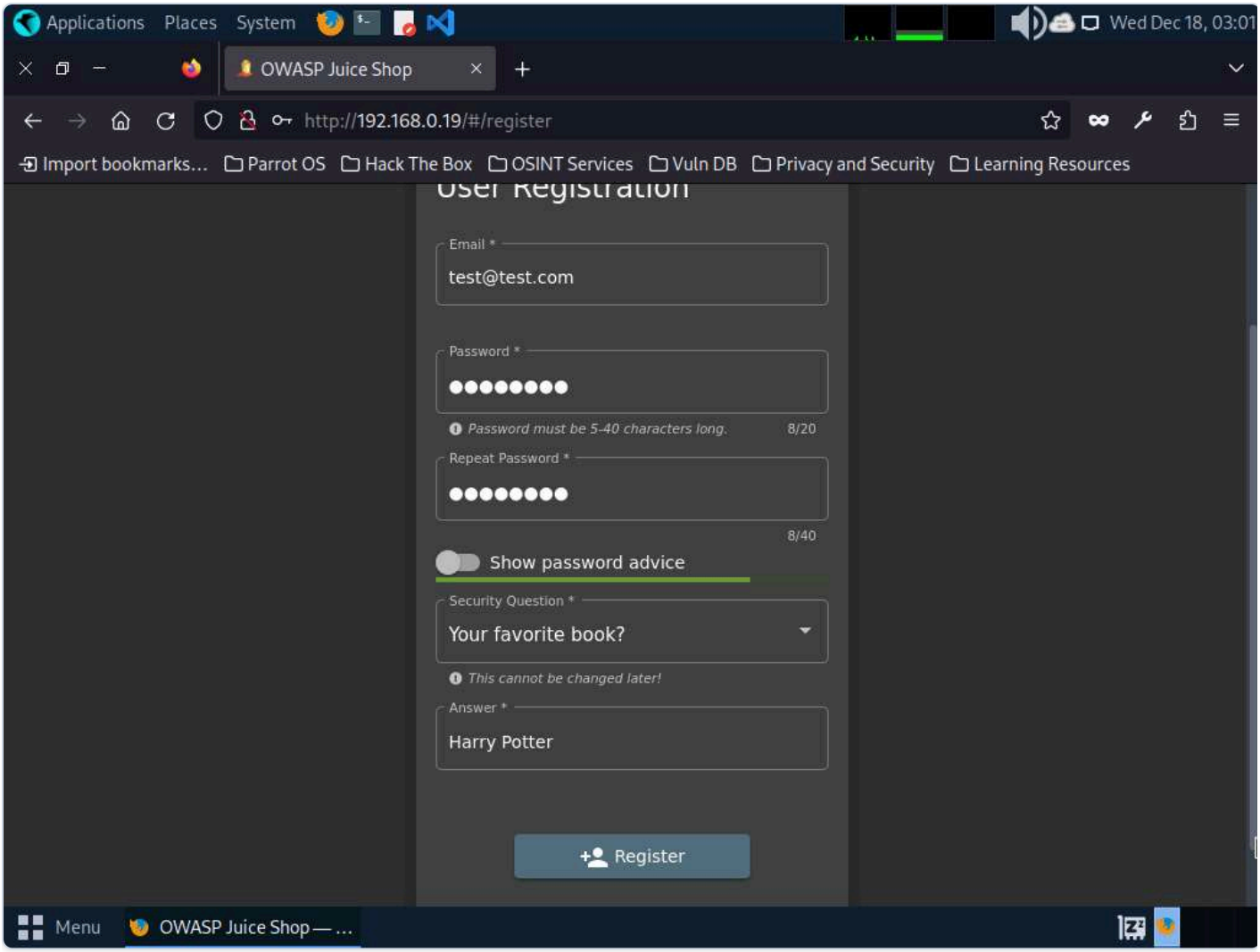
1. On the OWASP Juice Shop homepage, click **Account** --> **Login**.



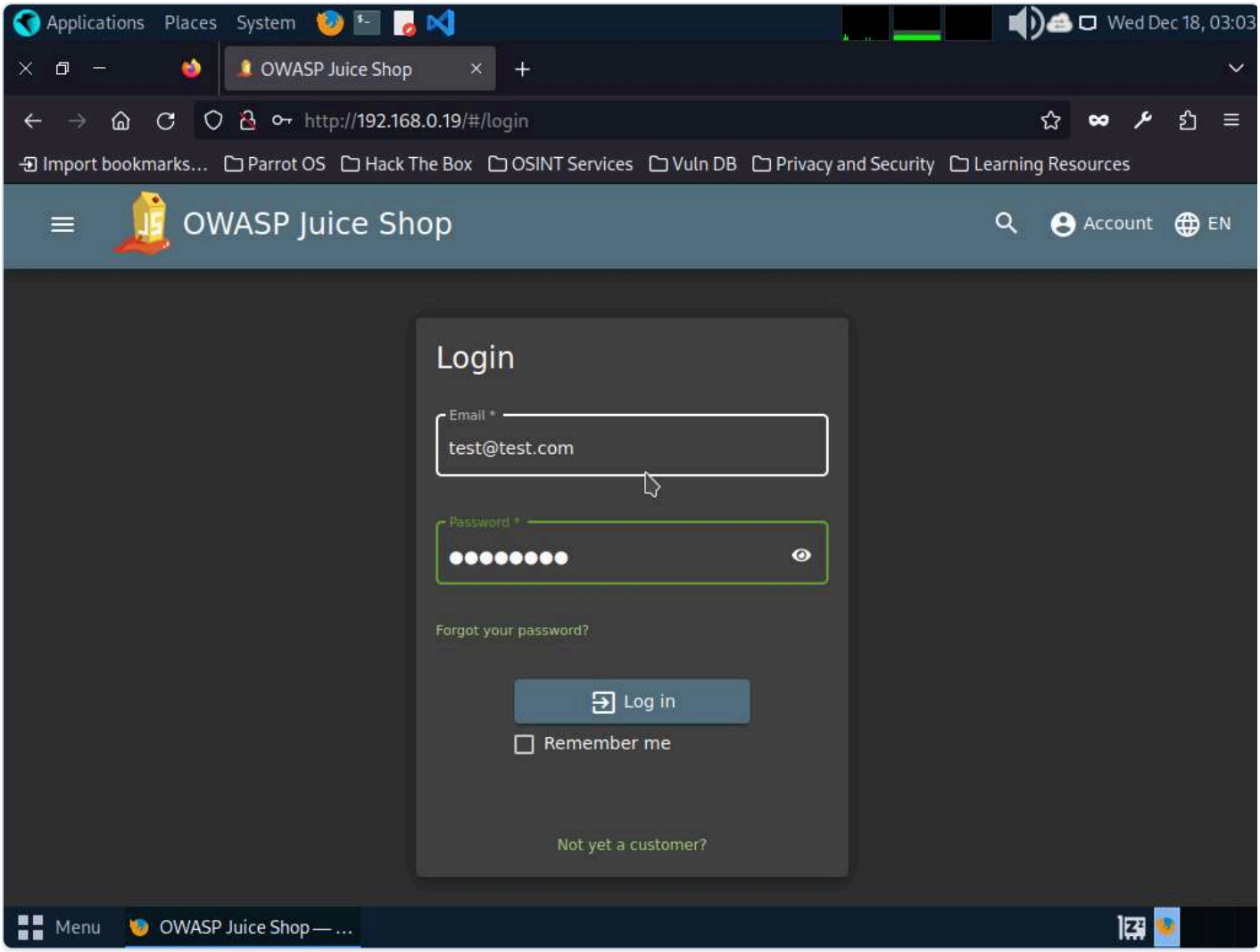
1. On the Login page, click **Not yet a customer?**.



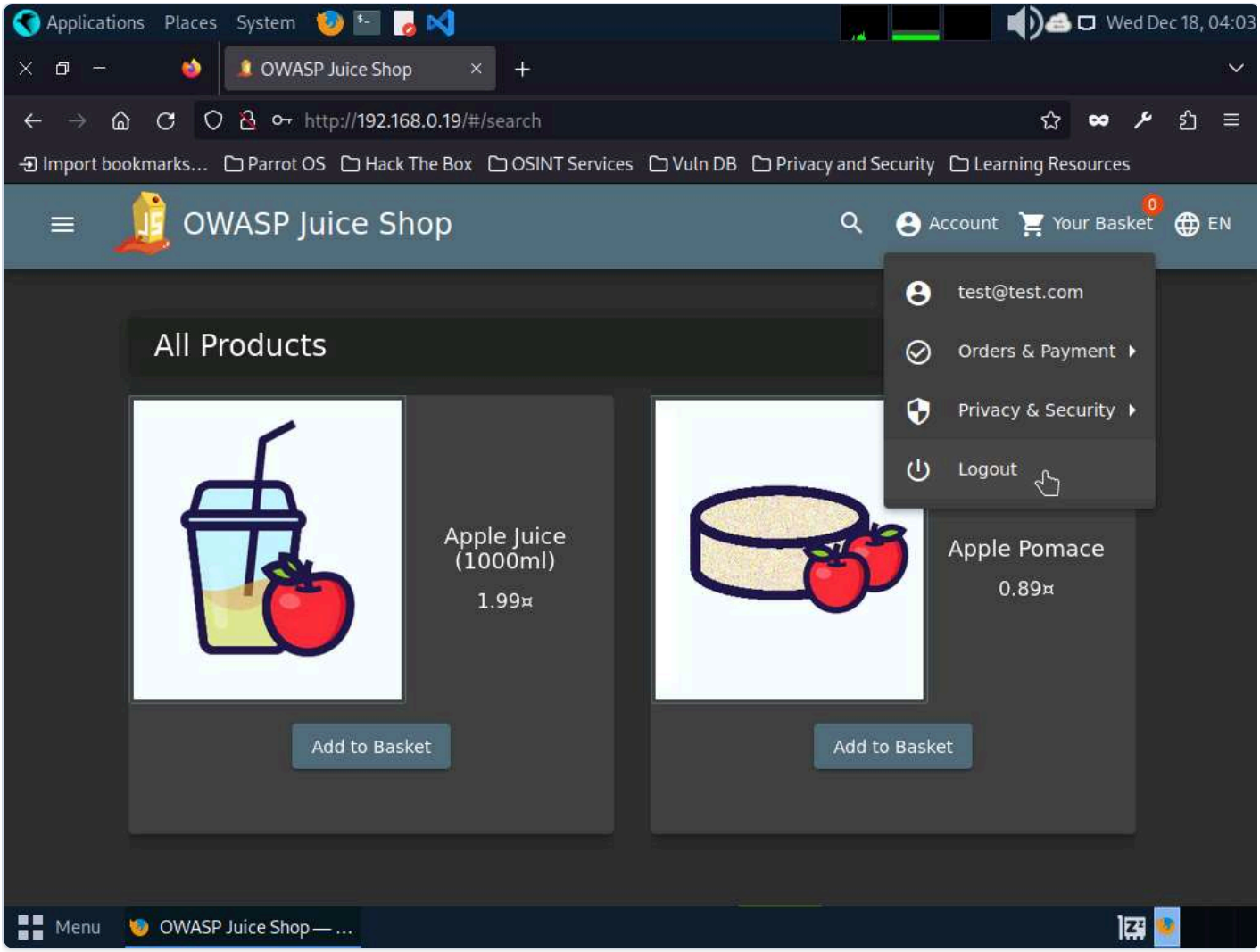
1. On the User Registration page, fill in all required fields and click **Register**.



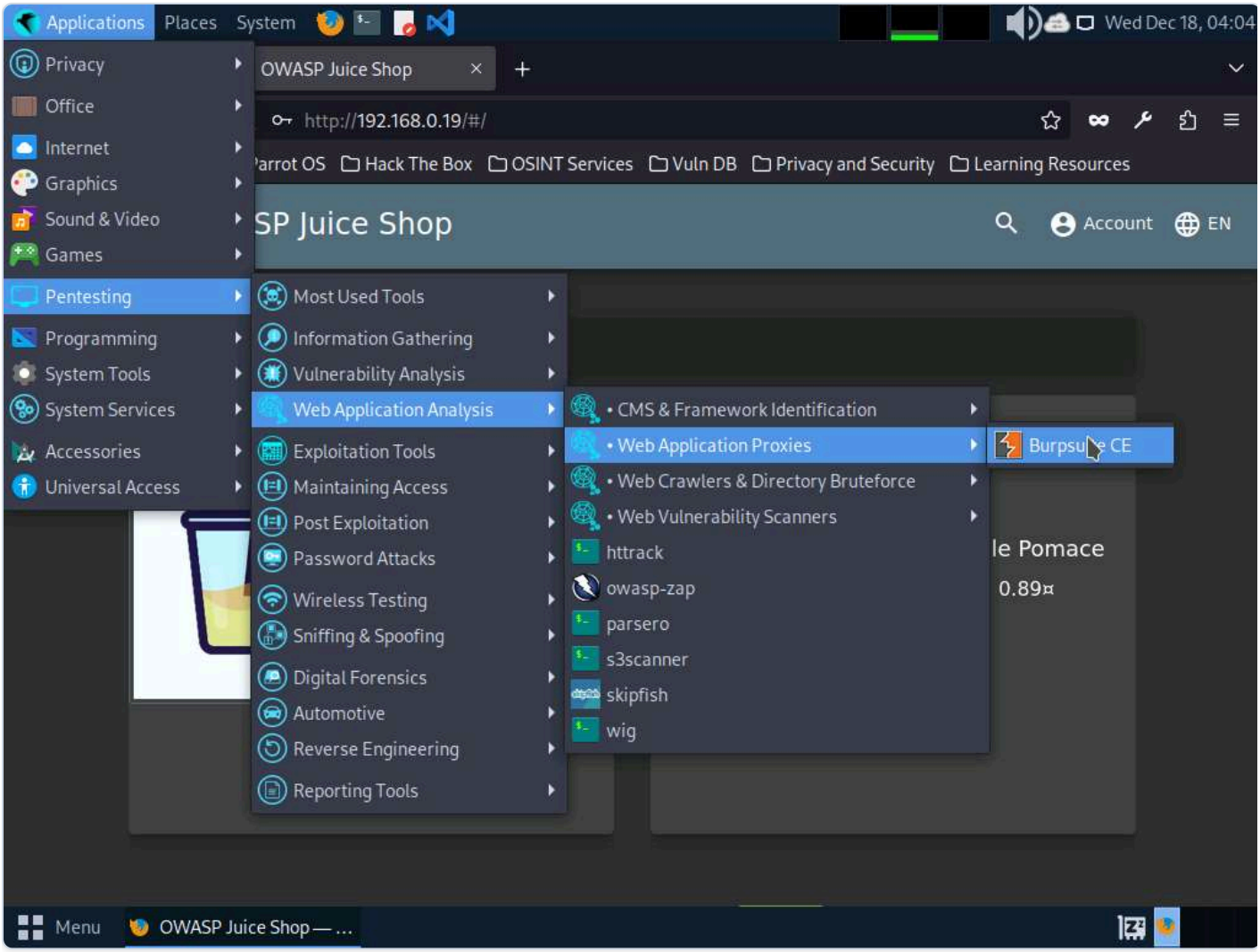
1. Once redirected to the login page, log in with the newly registered email address and password.



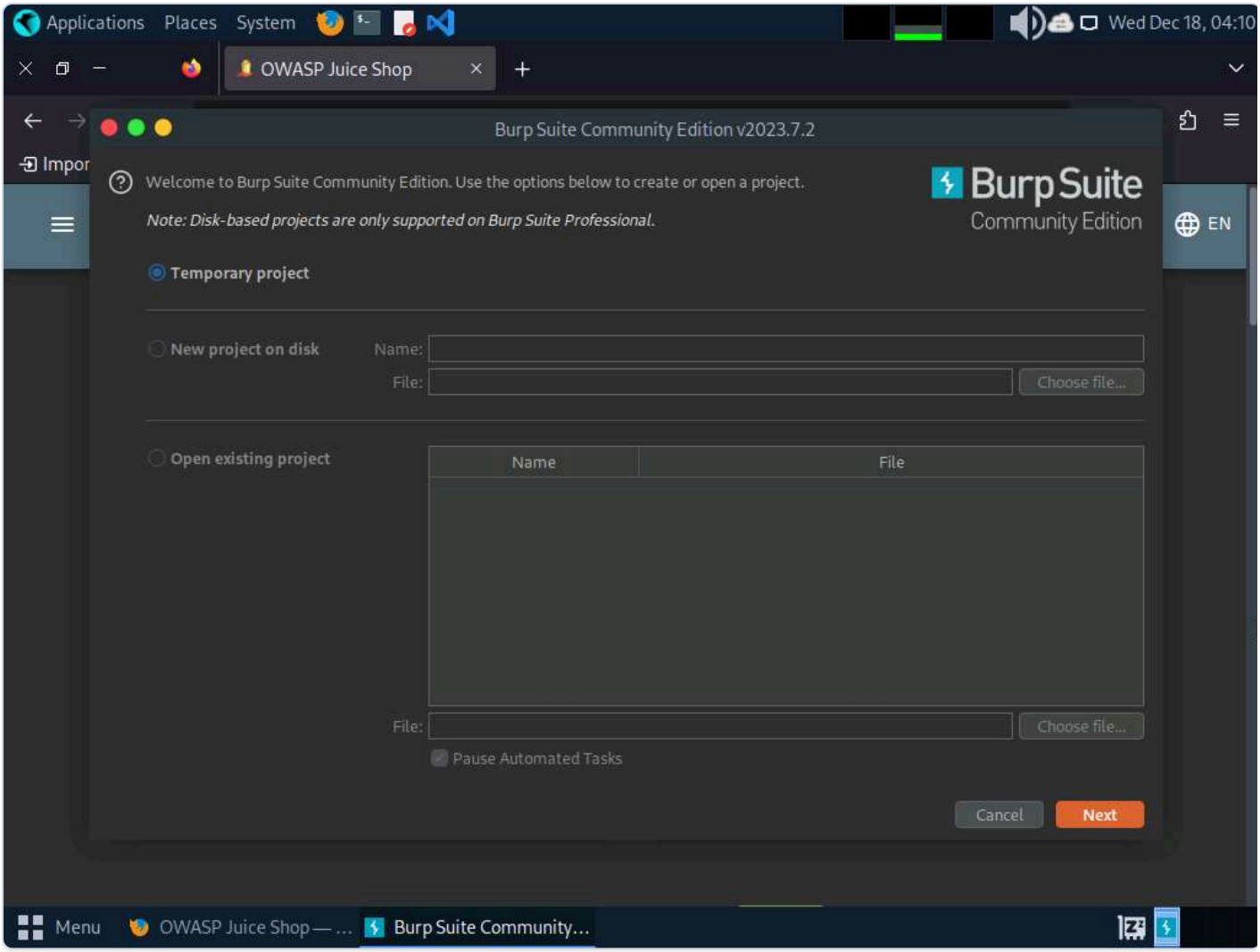
1. Upon successful login, log out of OWASP Juice Shop.



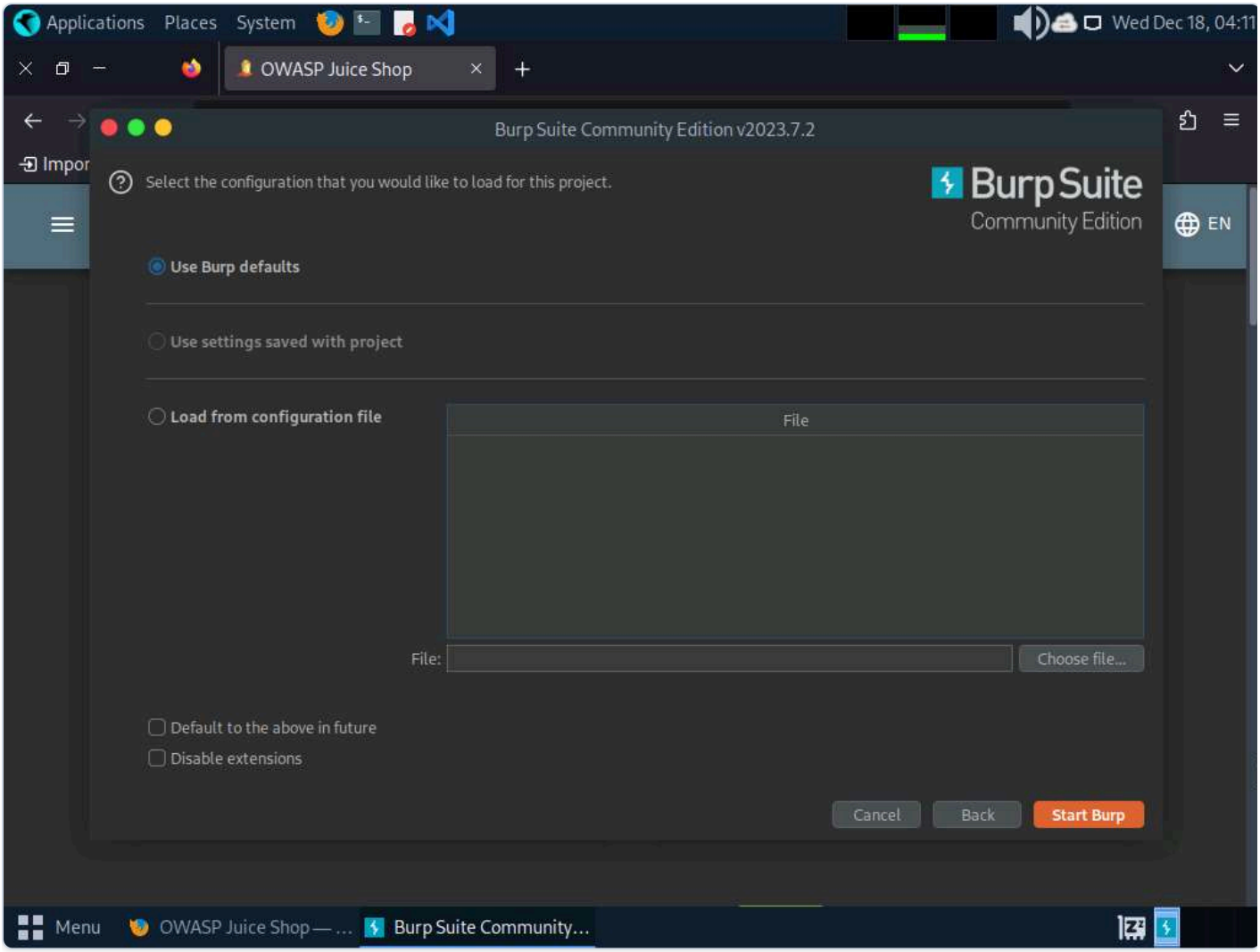
1. Launch Burp Suite by clicking **Applications** --> **Pentesting** --> **Web Application Analysis** --> **Web Application Proxies** --> **Burpsuite CE**.
2. In the Burp Suite Community Edition window click **OK**, and accept the Terms and Conditions.



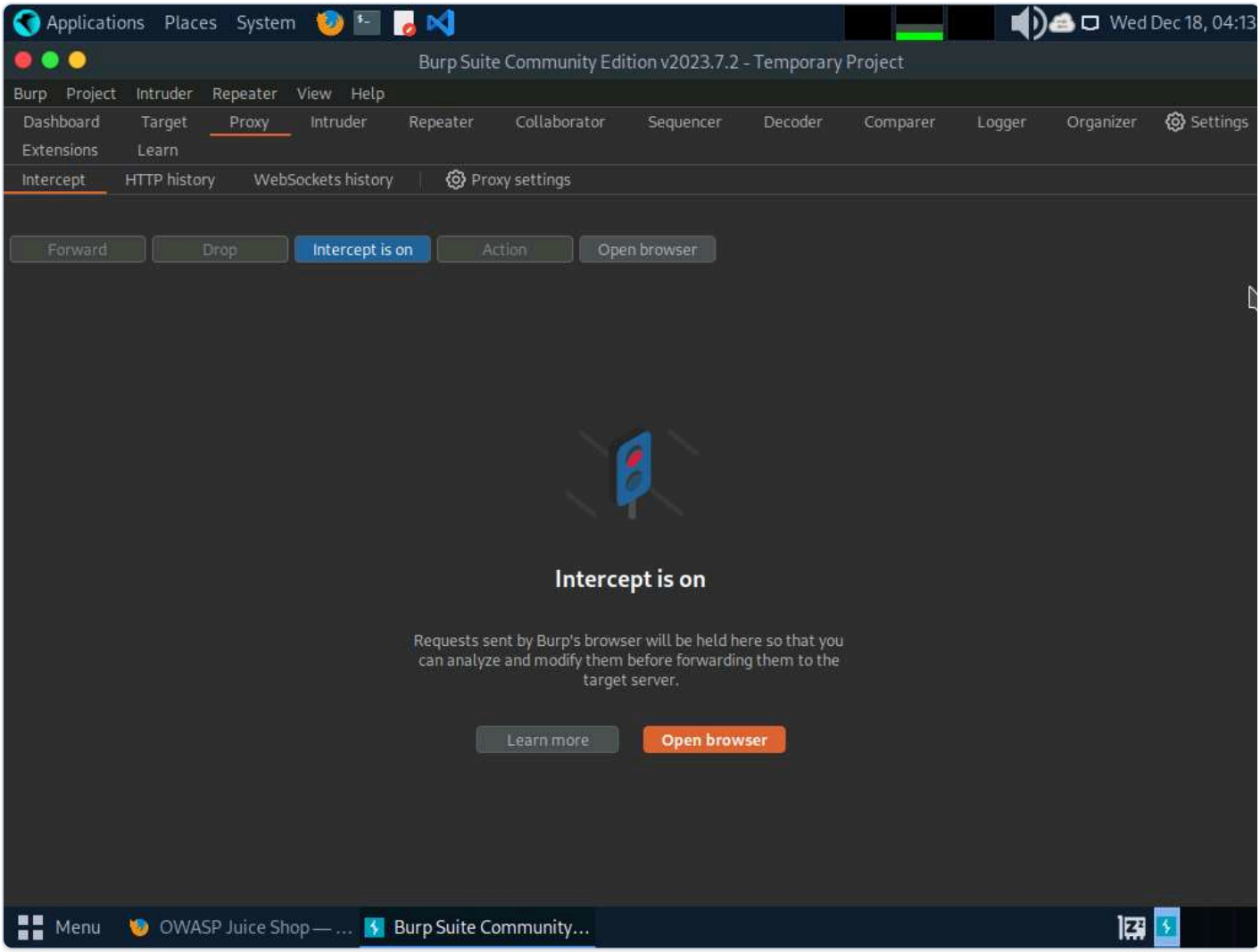
1. Keep the project settings as default (**Temporary project**) and click **Next**.



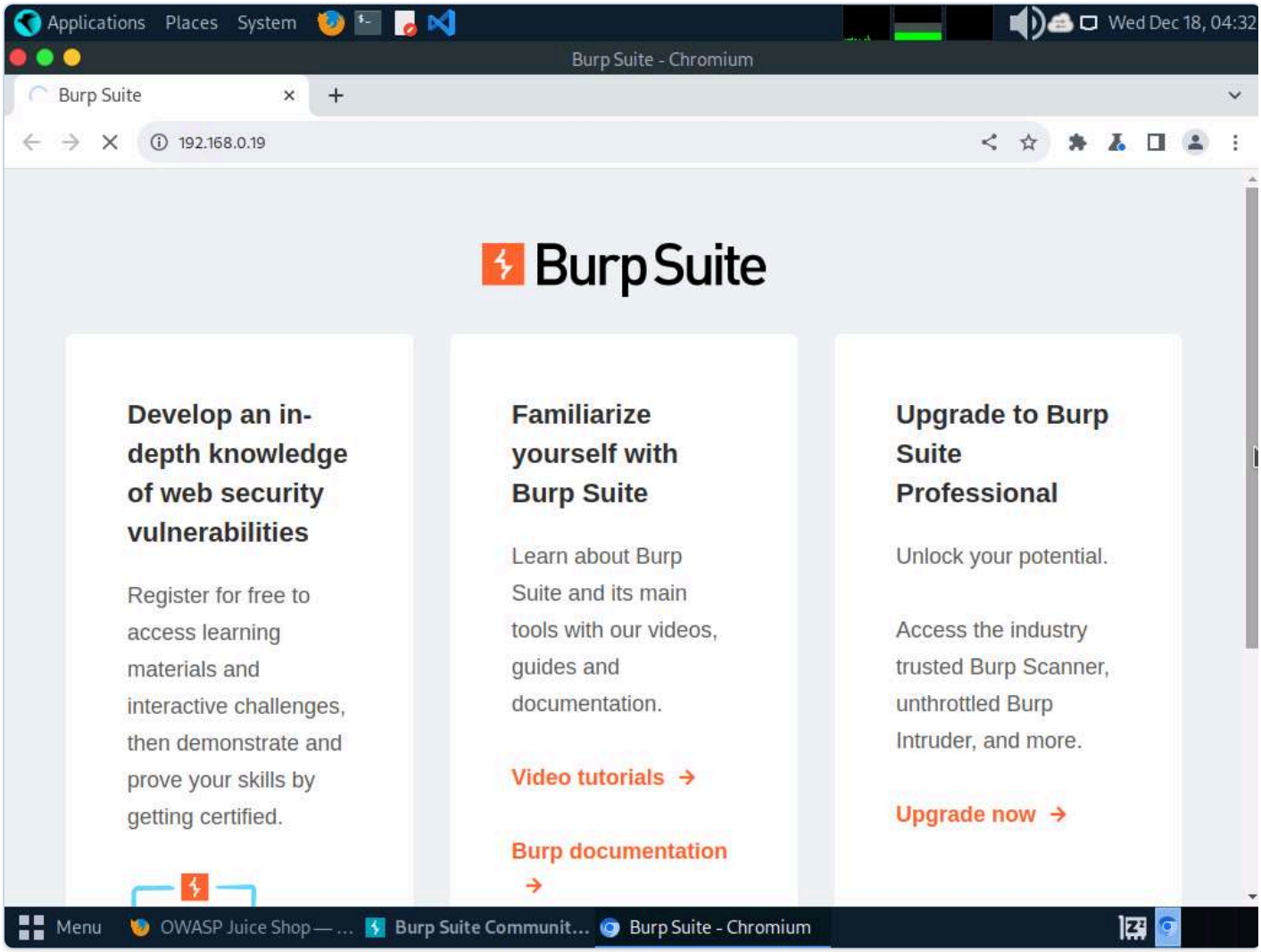
1. Select **Use Burp defaults** and click **Start Burp**.



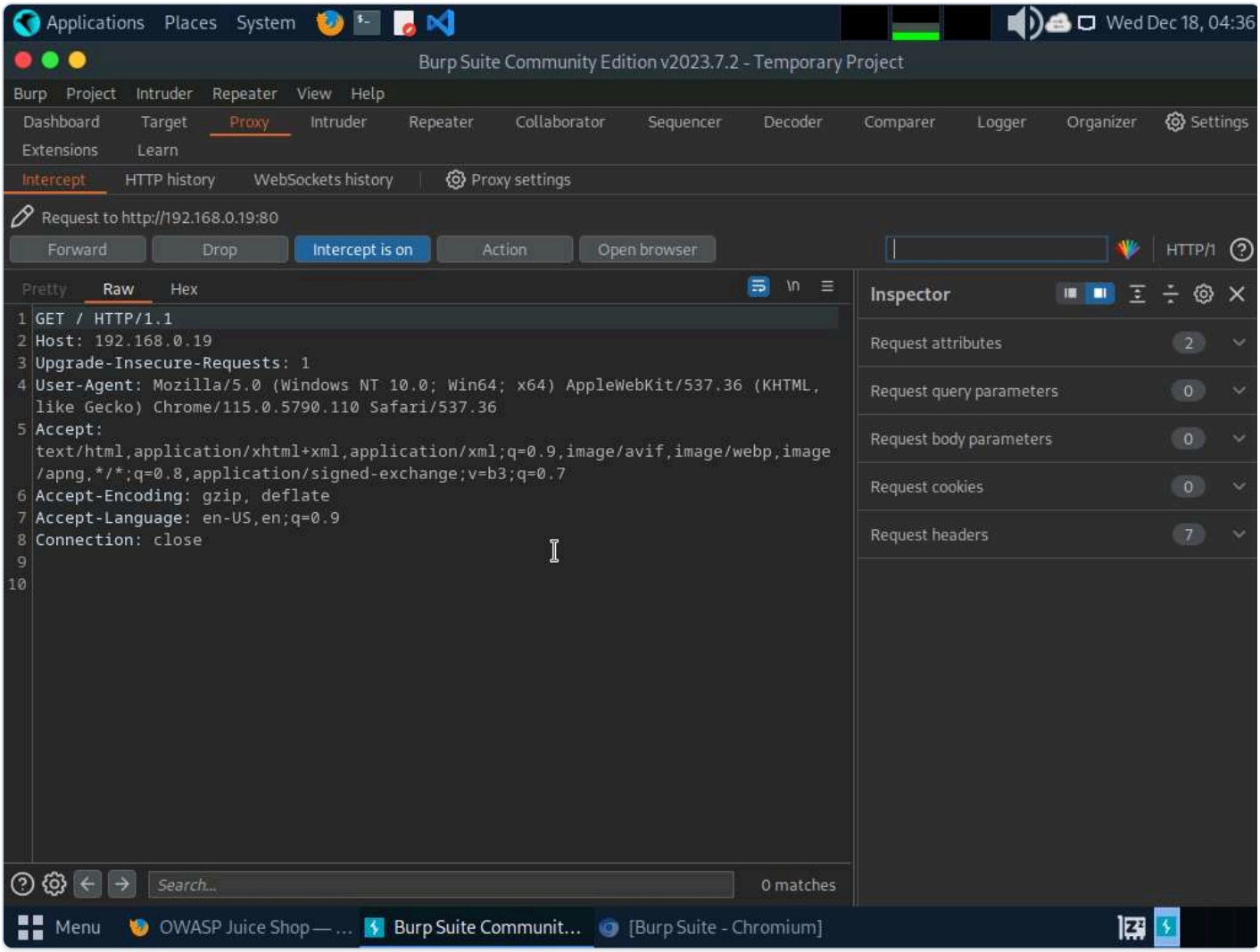
1. In Burp Suite, navigate to the **Proxy** tab and click **Open browser** to launch the embedded Chromium browser.



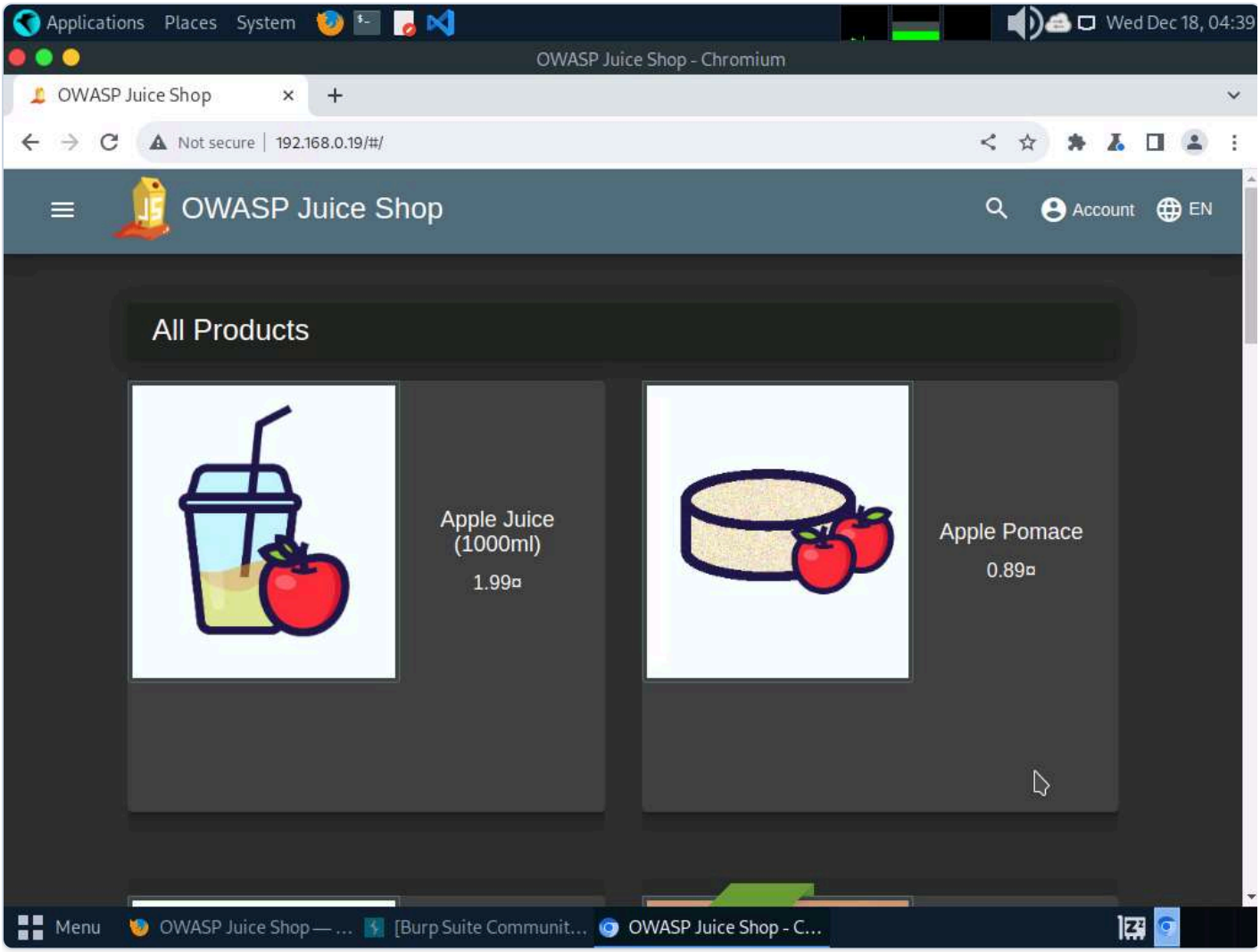
1. In the Burp browser address bar, type **http://192.168.0.19** and press Enter.



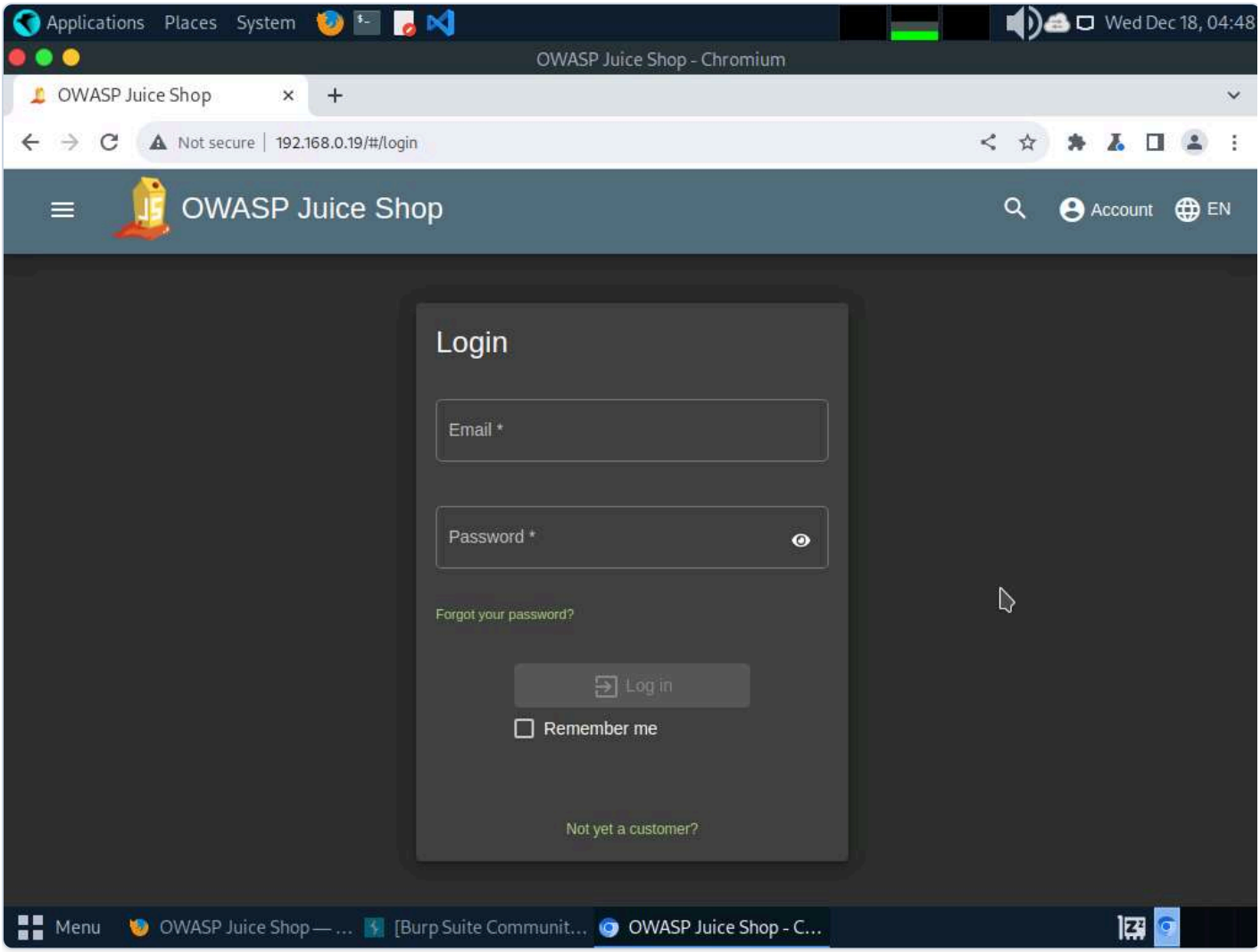
1. In Burp Suite under the **Proxy** --> **Intercept** tab, observe the captured HTTP request.



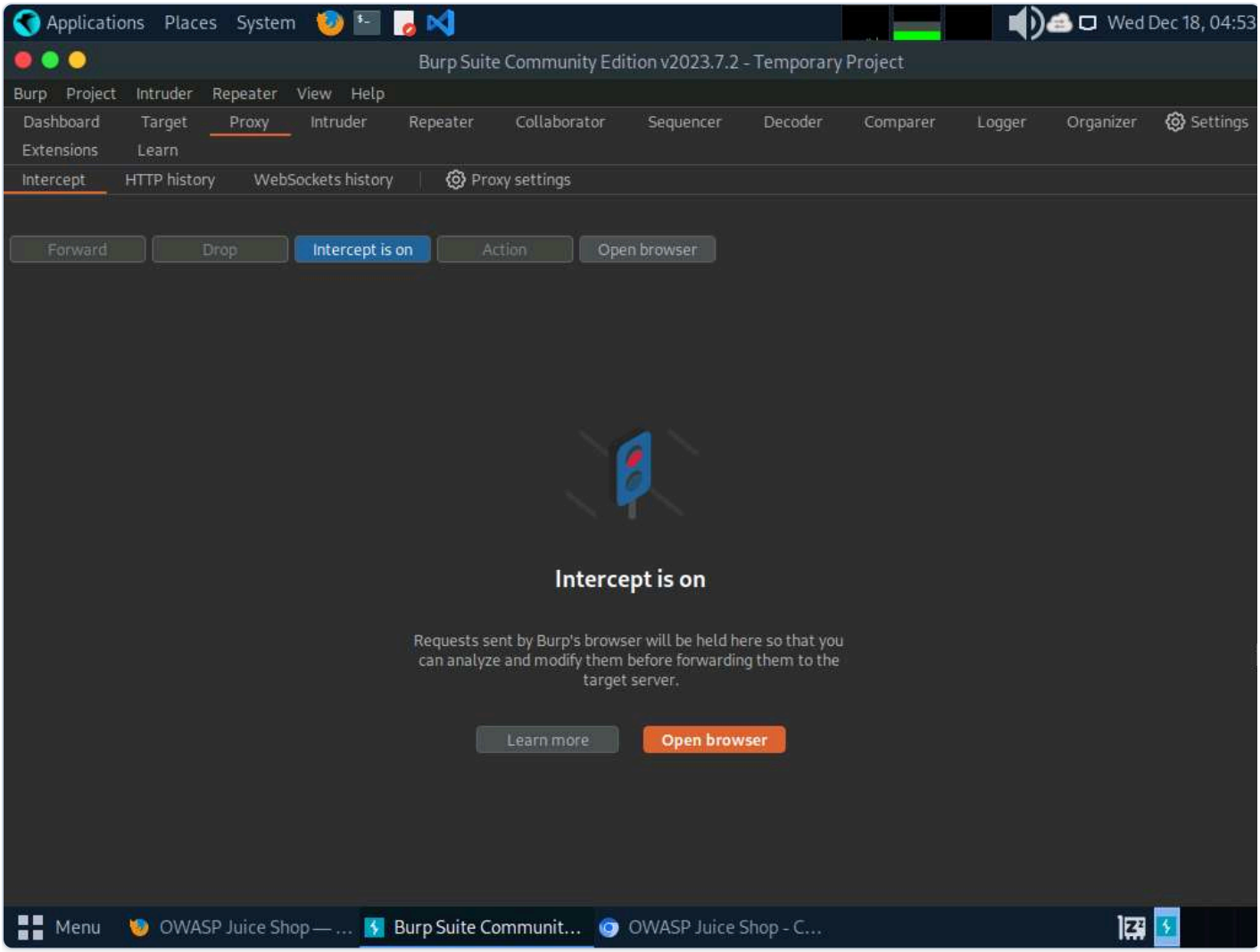
1. Click **Intercept is on** to toggle it to **Intercept is off**.



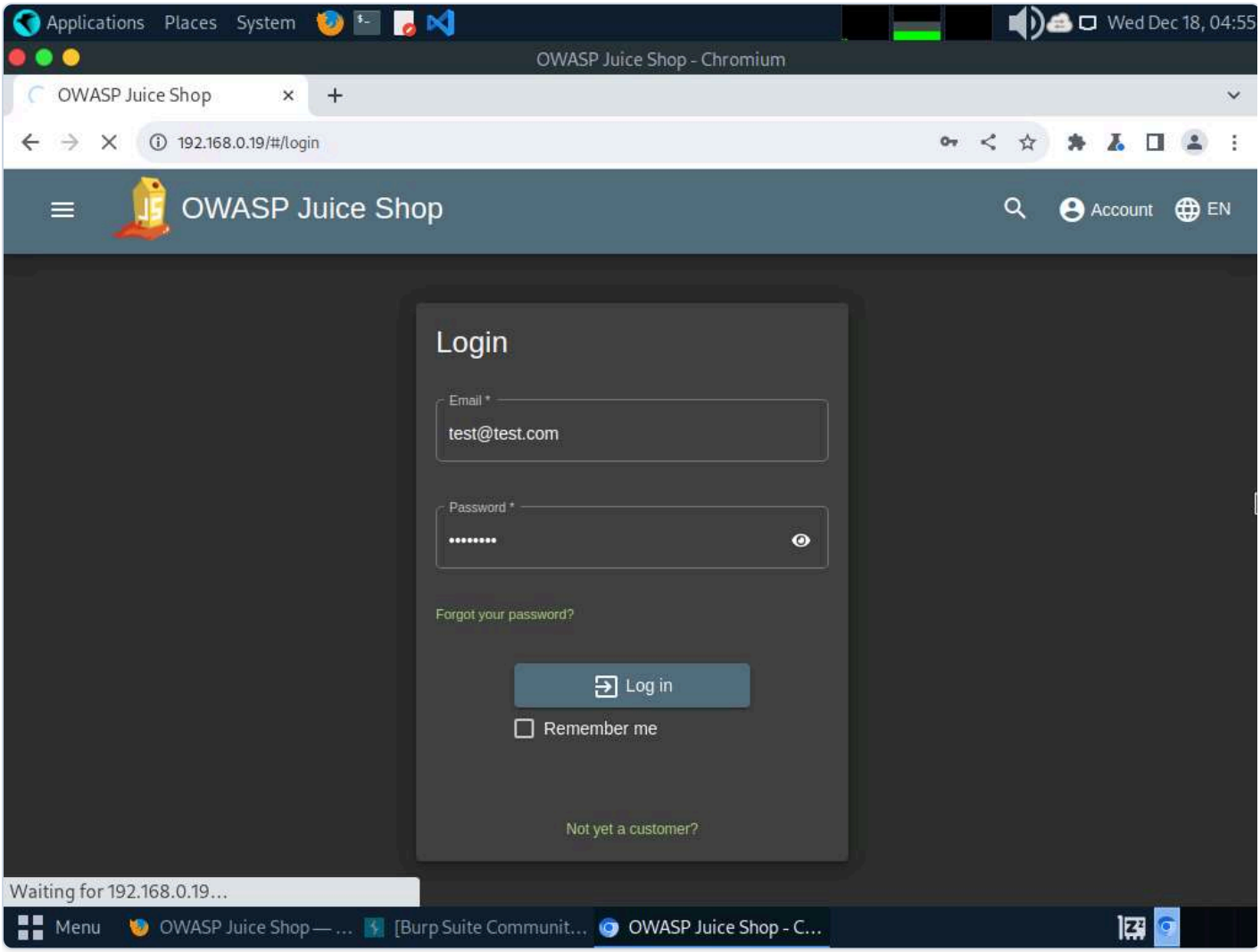
1. On the web page, click **Account** --> **Login** (reload page if necessary).



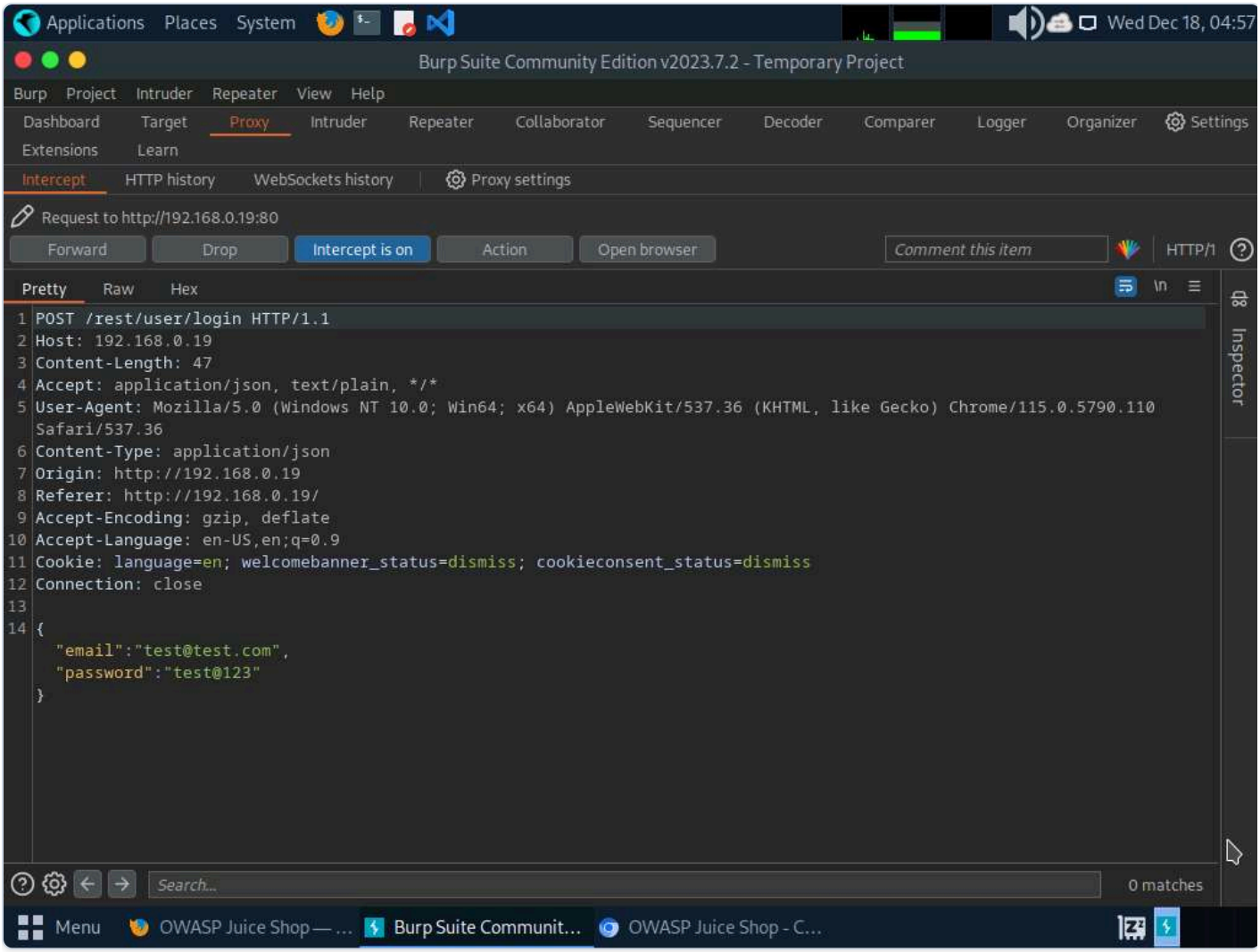
1. In Burp Suite **Proxy** tab, click **Intercept is off** to toggle it to **Intercept is on**.



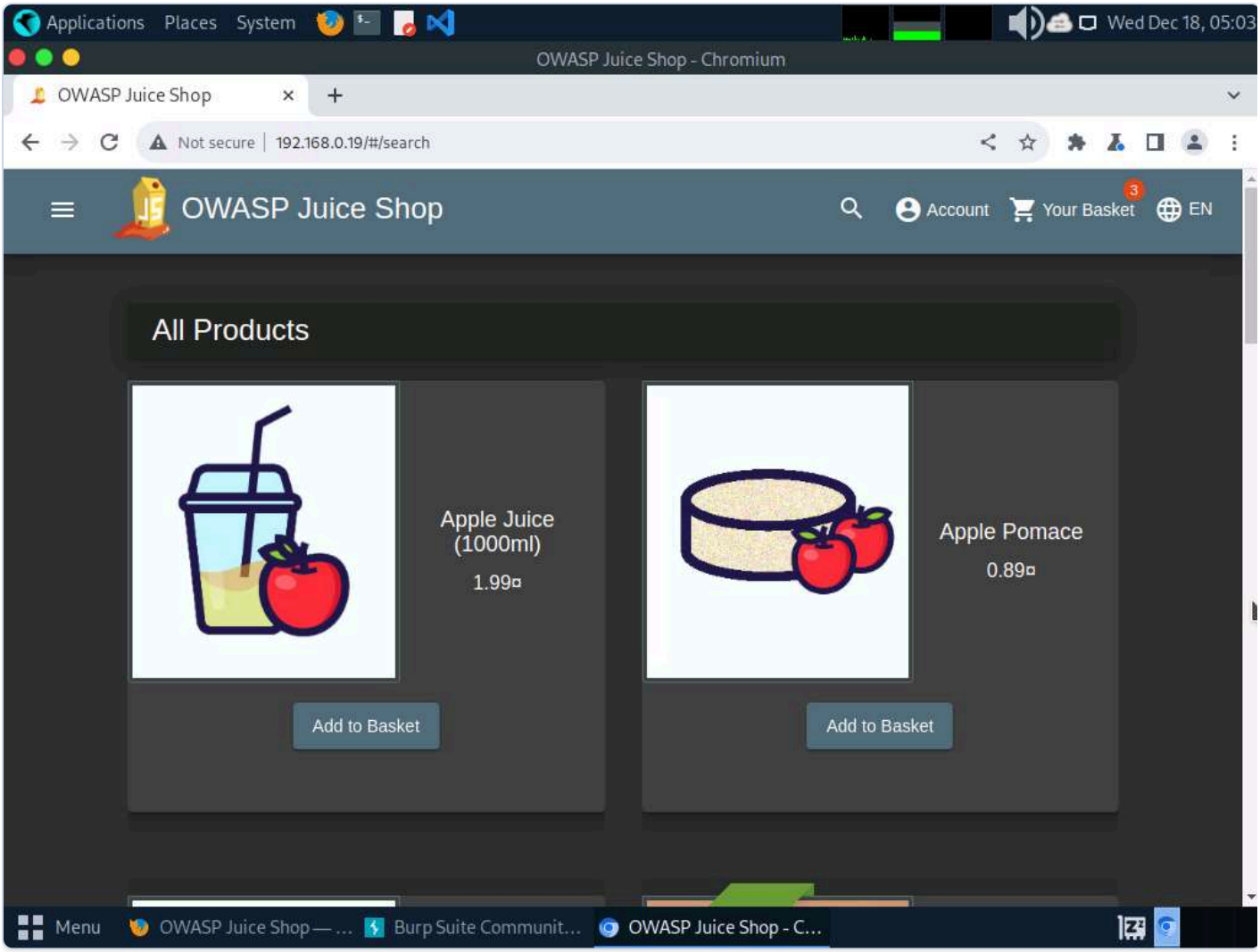
1. Return to the browser, enter your login credentials, and submit the form.



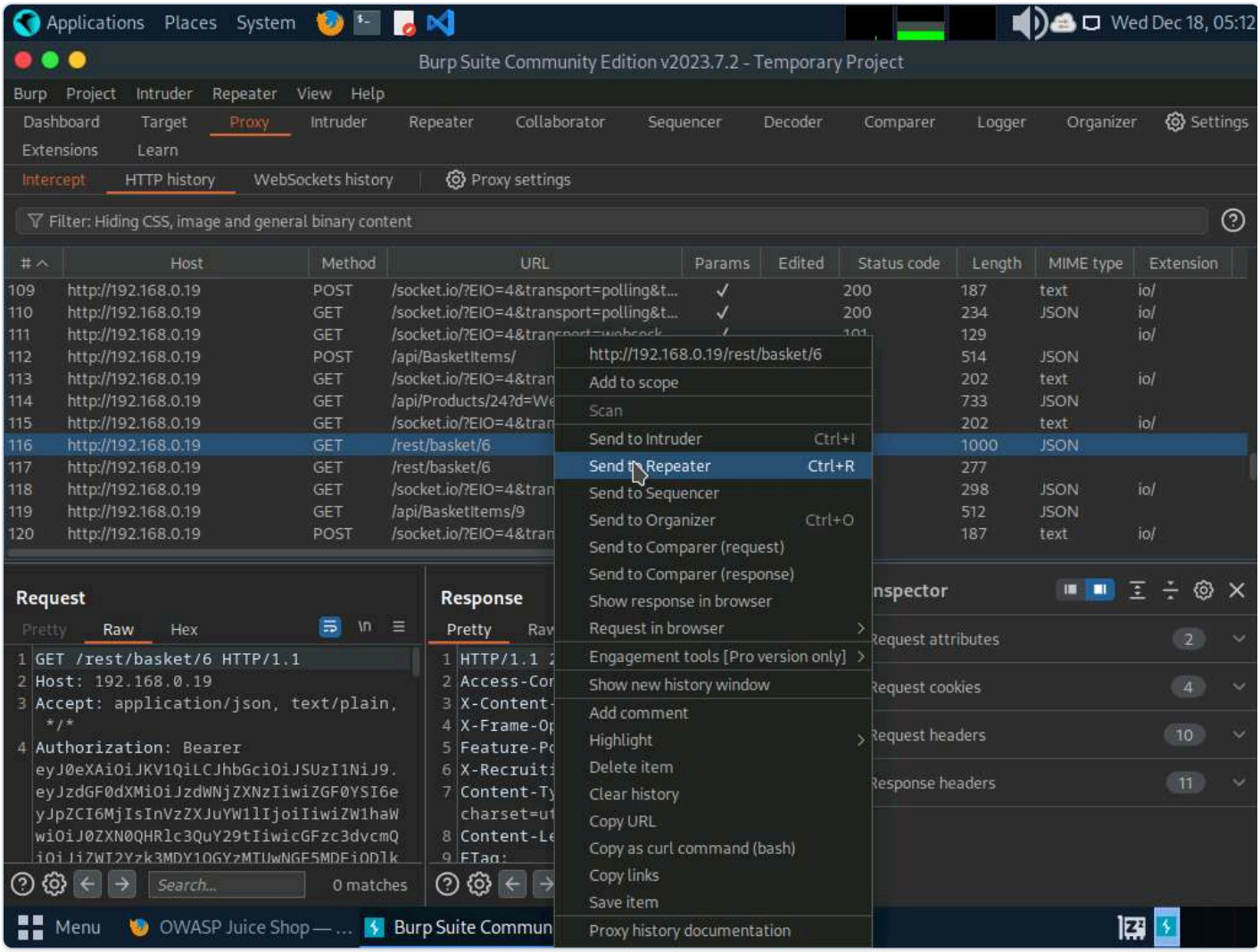
1. In Burp Suite, click **Forward** repeatedly to pass requests until the authentication request is completed.



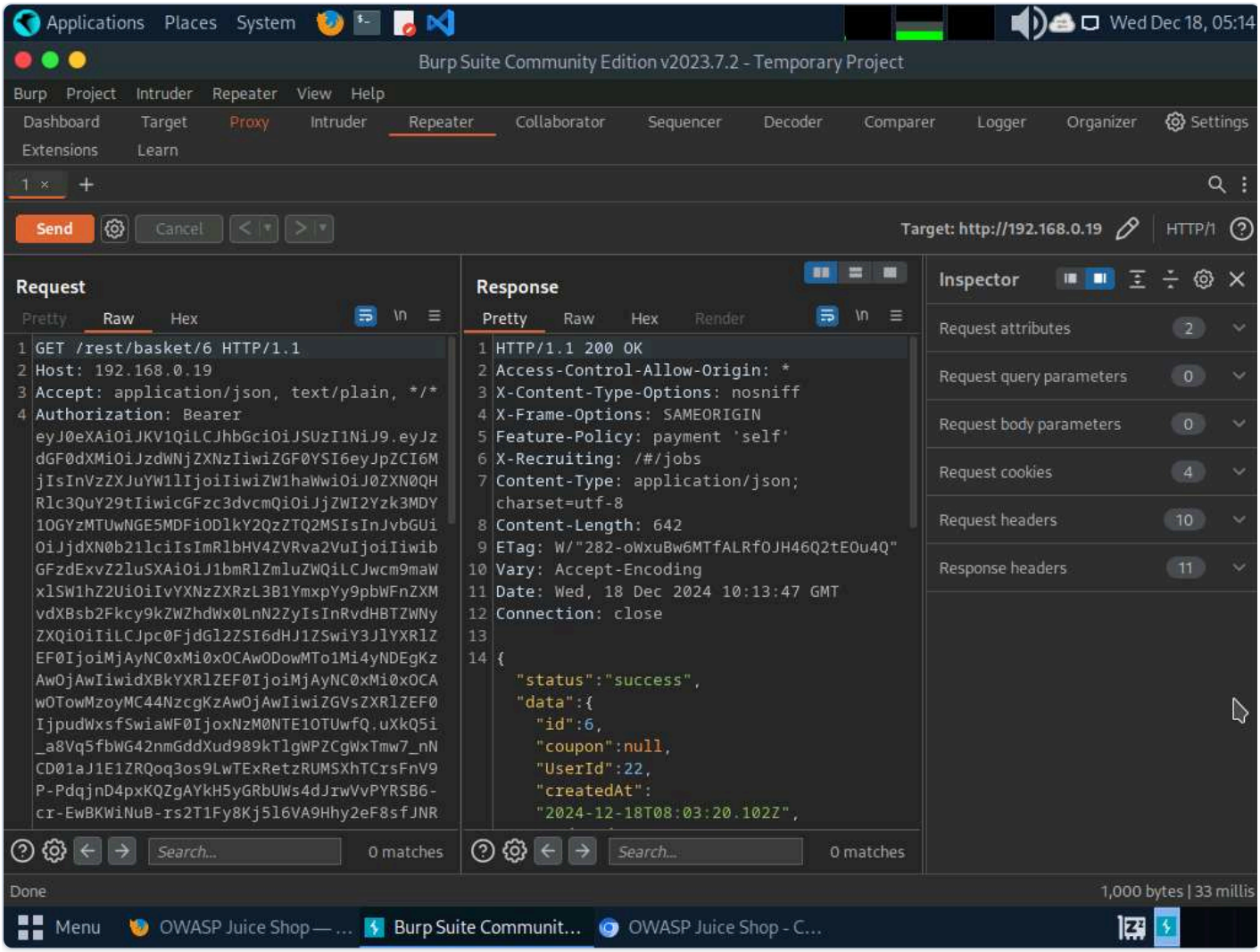
1. Turn off Intercept, reload the page, turn Intercept back on, and add 3 items to the basket. Click **Forward** after each item addition to pass all intercepted traffic.



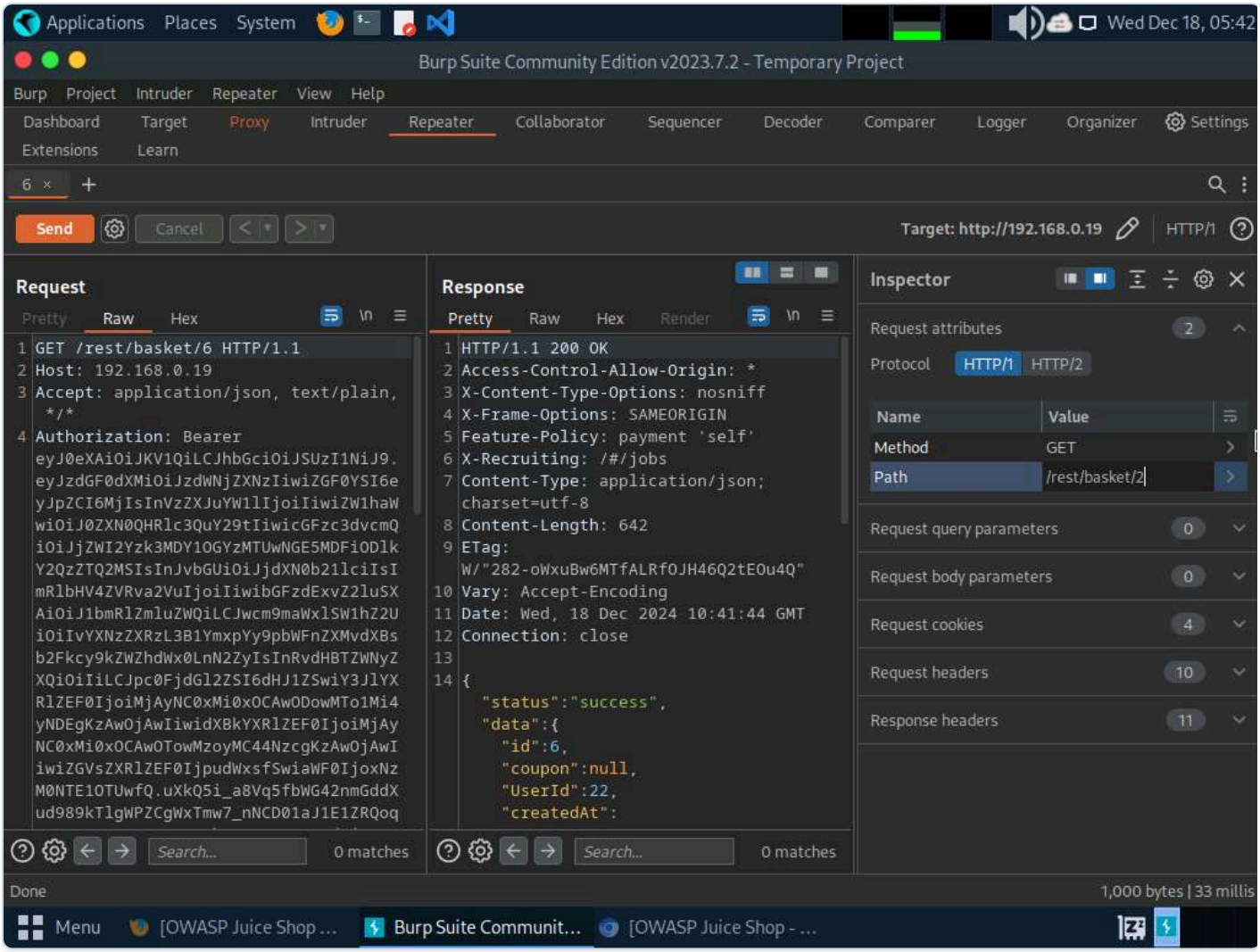
1. In Burp Suite, switch to the **HTTP history** sub-tab under the **Proxy** section. Locate the **GET /rest/basket** request with HTTP status code `200`, right-click it, and select **Send to Repeater**.



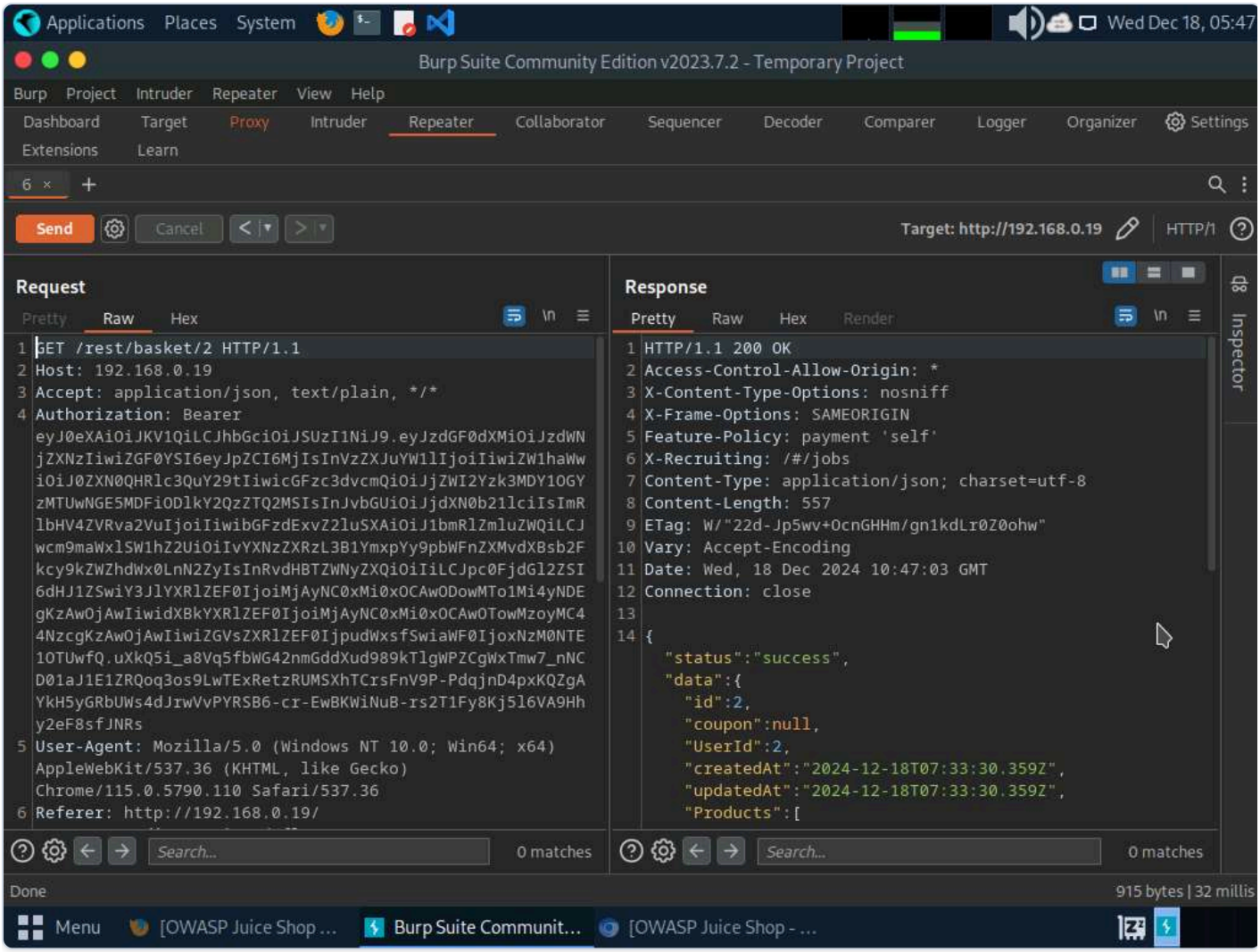
1. Navigate to the **Repeater** tab and click **Send** to verify the initial basket response.

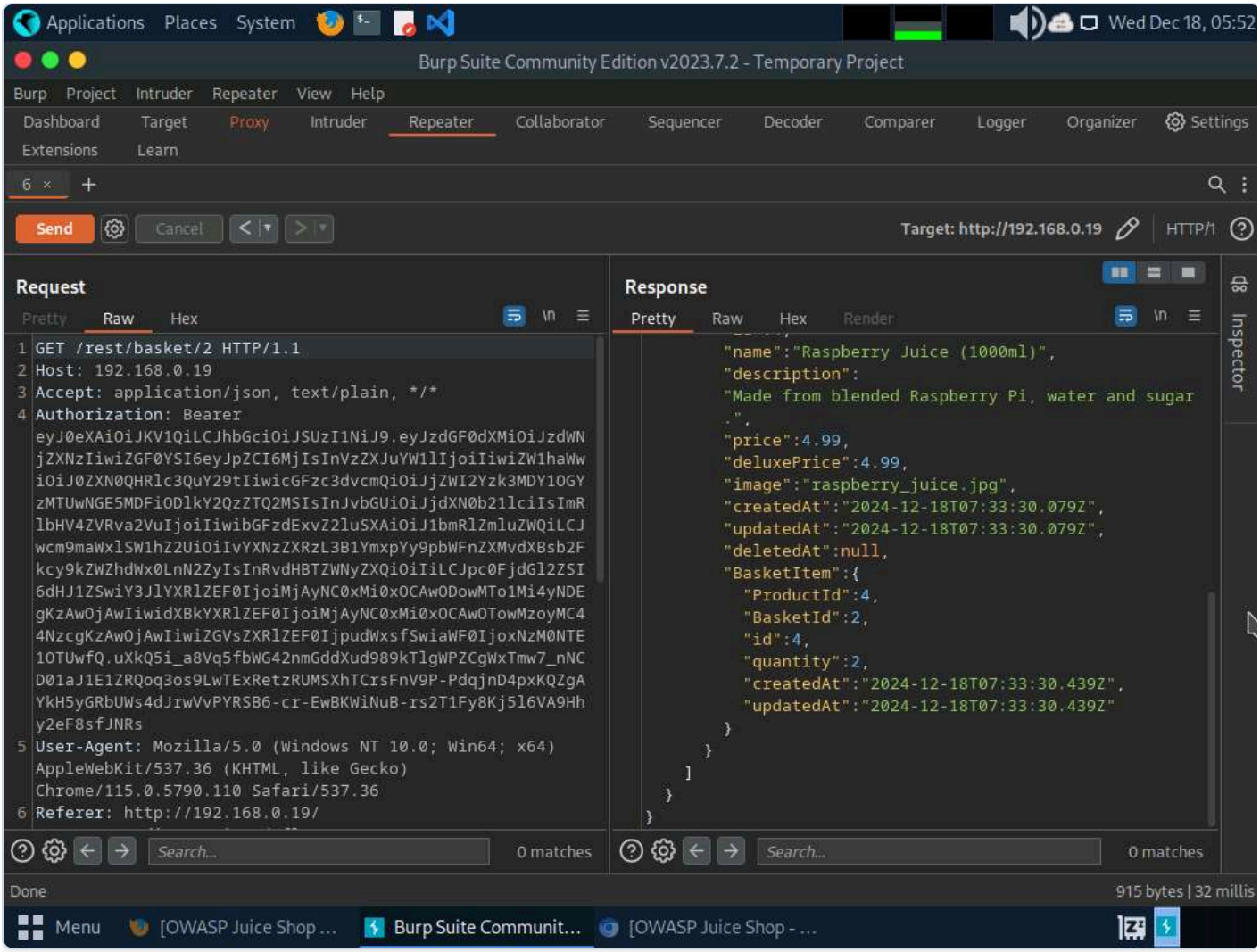


1. In Repeater, modify the basket ID in the URL path (e.g., change `/rest/basket/1` to **/rest/basket/2**).

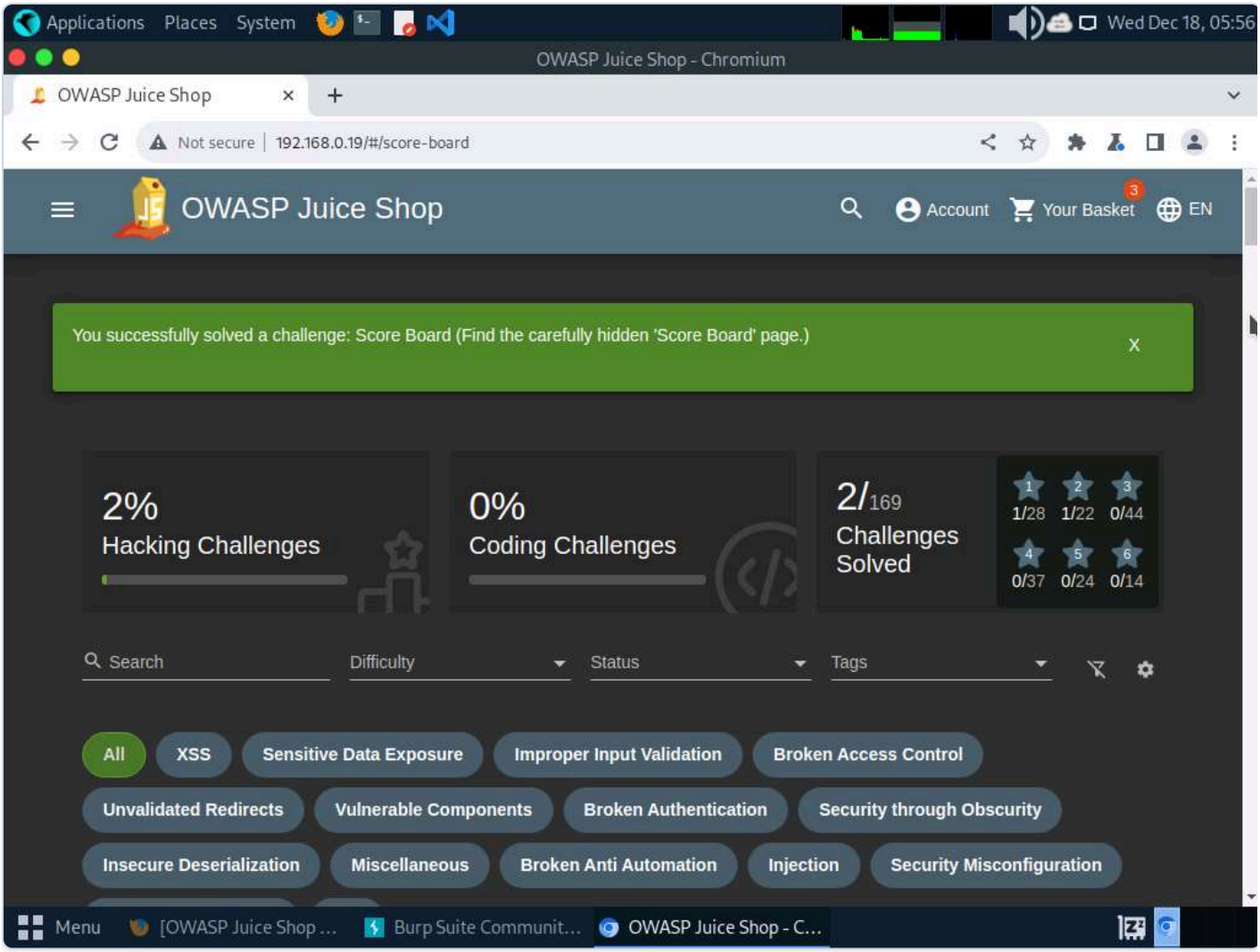


1. Click **Send** to transmit the modified request.


Applications Places System
Wed Dec 18, 05:47
Burp Suite Community Edition v2023.7.2 - Temporary Project
Burp Project Intruder Repeater View Help
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Settings
Extensions Learn
6 ×
Send Cancel
Target: http://192.168.0.19
HTTP/1
Request
Pretty Raw Hex
1 GET /rest/basket/2 HTTP/1.1
2 Host: 192.168.0.19
3 Accept: application/json, text/plain, */*
4 Authorization: Bearer
eyJ0eXAiOiJKV1QiLCJhbGciOiJSUzI1NiJ9.eyJzdGF0dXMiOiJzdWN
jZXNzIiwiZGF0YSI6eyJpZCI6MjIsInVzZXJuYW1lIjoiIiwiZW1haWw
iOiJ0ZXN0QHRlc3QuY29tIiwicGFzc3dvcmQiOiJjZWI2Yzk3MDY1OGY
zMTUwNGE5MDFiODlkY2QzZTQ2MSIsInJvbGUiOiJjdXN0b21lciIsImR
lbHV4ZVRva2VuIjoiIiwibGFzdExvZ2luSXAiOiJ1bmRlZmluZWQiLCJ
wcm9maWxlSW1hZ2UiOiIvYXNzZXRzL3B1YmxpYy9pbWFnZXMvdXBsb2F
kcy9kZWZhdWx0LnN2ZyIsInRvdHBTZWNyZXQiOiIiLCJpc0FjdGl2ZSI
6dHJ1ZSwiY3JlYXRlZEF0IjoiMjAyNC0xMi0xOCAwODowMTo1Mi4yNDE
gKzAwOjAwIiwidXBkYXRlZEF0IjoiMjAyNC0xMi0xOCAwOTowMzoyMC4
4NzcgKzAwOjAwIiwiZGVsZXRlZEF0IjpudWxsfSwiaWF0IjoxNzM0NTE
1OTUwfQ.uXkQ5i_a8Vq5fbWG42nmGddXud989kTlgWPZCgWxTmw7_nNC
D01aJ1E1ZRQoq3os9LwTExRetzRUMSXhTCrsFnV9P-PdqjnD4pxKQZgA
YkH5yGRbUWs4dJrwVvPYRSB6-cr-EwBKWiNuB-rs2T1Fy8Kj5l6VA9Hh
y2eF8sfJNRs
5 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/115.0.5790.110 Safari/537.36
6 Referer: http://192.168.0.19/
Search... 0 matches
Response
Pretty Raw Hex Render
1 HTTP/1.1 200 OK
2 Access-Control-Allow-Origin: *
3 X-Content-Type-Options: nosniff
4 X-Frame-Options: SAMEORIGIN
5 Feature-Policy: payment 'self'
6 X-Recruiting: /#/jobs
7 Content-Type: application/json; charset=utf-8
8 Content-Length: 557
9 ETag: W/"22d-Jp5wv+OcnGHHm/gn1kdLr0Z0ohw"
10 Vary: Accept-Encoding
11 Date: Wed, 18 Dec 2024 10:47:03 GMT
12 Connection: close
13
14 {
"status":"success",
"data":{
"id":2,
"coupon":null,
"UserId":2,
"createdAt":"2024-12-18T07:33:30.359Z",
"updatedAt":"2024-12-18T07:33:30.359Z",
"Products":[
Search... 0 matches
Inspector
Done
915 bytes | 32 millis
Menu
[OWASP Juice Shop ...
Burp Suite Communit...
[OWASP Juice Shop - ...



1. Observe that by modifying the basket ID parameter, you successfully access shopping cart data belonging to other registered users, demonstrating a Broken Object-level Authorization (BOLA) vulnerability.
2. Optional: To activate the challenge scoreboard, disable Intercept and navigate to **http://192.168.0.19/#/score-board** in the browser.



1. Close all open windows.

IMPORTANT: ❓ **Question 5.5.1.1** On the Parrot Security machine, utilize Burp Suite to exploit a broken object-level authorization vulnerability in the OWASP Juice Shop, hosted at `http://192.168.0.19`. Modify the `GET /rest/basket` request, then determine the tab where HTTP traffic intercepted by Burp Proxy is recorded. [!SUCCESS]
✅ **Answer:** **HTTP history**